

AWS Security Fundamentals

IAM, detection, and workload protection across the AWS Well-Architected security pillar

Overview

AWS security rests on the shared responsibility model: AWS secures the cloud infrastructure, the customer secures configurations, identity, and data within it. Strong postures combine tight IAM, continuous detection (GuardDuty/Security Hub), and encryption/network controls enforced through Organizations-wide guardrails.

IAM Core Concepts

	Details
IAM Policy	JSON document granting/denying actions on resources; identity-based or resource-based
Role	Assumable identity with temporary credentials — preferred over long-lived IAM user keys
IAM Identity Center	Centralized SSO across AWS Organizations accounts (successor to AWS SSO)
SCP (Service Control Policy)	Org-level permission guardrail — sets the maximum boundary, doesn't itself grant access
Permission Boundary	Caps the maximum permissions an IAM identity can have, even if its policy grants more
Trust Policy	Defines who/what can assume a role (cross-account, federated, service)

Detection & Monitoring Services

- **GuardDuty** — ML-based threat detection over CloudTrail, VPC Flow Logs, DNS logs; no agents required
- **Security Hub** — aggregates findings from GuardDuty, Inspector, Macie, third-party tools against CIS/AWS FSBP benchmarks
- **CloudTrail** — API call audit log; enable multi-region, organization trail, log-file integrity validation

- **AWS Config** — continuous resource configuration recording and compliance rule evaluation
- **Inspector** — automated vulnerability scanning for EC2, ECR images, and Lambda functions
- **Macie** — ML-based discovery and classification of sensitive data in S3

Network & Data Protection

- **Security Groups** — stateful, instance-level virtual firewall (allow rules only)
- **NACLs** — stateless, subnet-level; supports explicit deny, evaluated in rule-number order
- **VPC endpoints (Gateway/Interface)** — keep traffic to S3/DynamoDB/other services off the public internet
- **KMS** — centralized key management; CMKs with defined key policies and automatic/manual rotation
- **S3 Block Public Access** — account/bucket-level setting that should be enabled by default org-wide
- **AWS WAF + Shield** — L7 filtering and DDoS protection in front of ALB/CloudFront/API Gateway

Landing Zone / Multi-Account Pattern

AWS Organizations root → OUs (Security, Infrastructure, Workloads) → SCP guardrails per OU → dedicated **Log Archive** and **Security Tooling** accounts receive aggregated CloudTrail/Config/GuardDuty findings, isolated from workload accounts to preserve audit integrity even if a workload account is compromised.

Well-Architected Security Pillar — Design Principles

- Implement a **strong identity foundation** — least privilege, centralized identity, eliminate long-term credentials where possible
- Enable **traceability** — log and monitor, integrate alerts with automated response
- Apply security **at all layers** — edge network, VPC, subnet, load balancer, instance, OS, application, code
- **Automate security best practices** — codify controls as scalable, repeatable IaC
- **Prepare for security events** — incident response playbooks, game days, forensics-ready account design

Common Pitfalls

	Fix
Long-lived IAM user access keys	Prefer roles with temporary STS credentials; enforce key rotation/ expiry where keys are unavoidable
Single-account sprawl with no guardrails	Adopt AWS Organizations + SCPs across a multi-account landing zone
CloudTrail enabled in one region only	Enable an organization trail covering all regions with log-file validation
Overly permissive S3 bucket policies	Enable Block Public Access by default; audit with Access Analyzer
GuardDuty findings reviewed manually and late	Route findings through Security Hub into EventBridge-driven auto-remediation

Interview / Exam Quick Hits

- SCPs **never grant** permissions — they only restrict the maximum available permission set for an account
- GuardDuty findings feed automatically into **Security Hub** and can trigger **EventBridge**-driven auto-remediation
- Security Groups: **stateful** (return traffic auto-allowed); NACLs: **stateless** (must allow both directions explicitly)
- Cross-account access should use **IAM roles with external ID**, not shared long-lived credentials
- S3 bucket policies + IAM policies are evaluated together — an explicit **Deny** in either always wins